Содержание

1. Проблема и окно возможностей **2**

2. Продукт: как работает AppMOT **3**

2.1. Три шага пользователя . . . 3

2.2. Оценка A–D . . . 3

2.3. Бейдж доверия . . . 4

2.4. Демо-режим . . . 4

3. Рынок, конкуренты и ров **4**

3.1. Оценка объёма рынка . . . 4

3.2. Конкурентное поле . . . 4

3.3. Ров . . . 5

4. Архитектура MVP **5**

4.1. Принципы движка . . . 6

5. Каталог проверок движка v1 **7**

6. API-спецификация **8**

7. Юнит-экономика **9**

7.1. Тарифная сетка . . . 9

7.2. Экономика скана и подписчика (оценки) . . . 9

8. План первых 90 дней **10**

9. Дорожная карта на 12 месяцев **11**

10. Риски и митигации **12**

1. Проблема и окно возможностей

За 2025–2026 годы создание программного обеспечения перестало быть узким местом. Инструменты вайб-кодинга — Lovable, Replit, Bolt.new, v0, Base44 — позволили человеку без инженерного образования собрать работающее приложение за вечер по описанию на естественном языке. Результат налицо: только за первое полугодие 2026 года в App Store и Google Play вышло около 1,3 млн новых приложений, значительная часть которых создана людьми, впервые написавшими софт в жизни. Производственный цикл «идея → прототип → публикация» сжался с месяцев до дней.

Но за скорость генерации не успели ни проверка, ни сопровождение. Бенчмарк Veracode 2026 года по более чем сотне языковых моделей показывает: 45% сгенерированного ИИ кода не проходит тесты безопасности, и этот показатель практически не меняется четыре года подряд. Внутреннее исследование ICSE-SEIP'26 фиксирует, что 68% вайб-кодеров описывают собственный код как «быстрый, но дырявый», а 36% вообще пропускают этап контроля качества. Массовый скан более 380 000 публичных приложений, опубликованный на платформах Lovable, Replit, Base44 и Netlify, обнаружил утечку чувствительных данных примерно в 40% случаев.

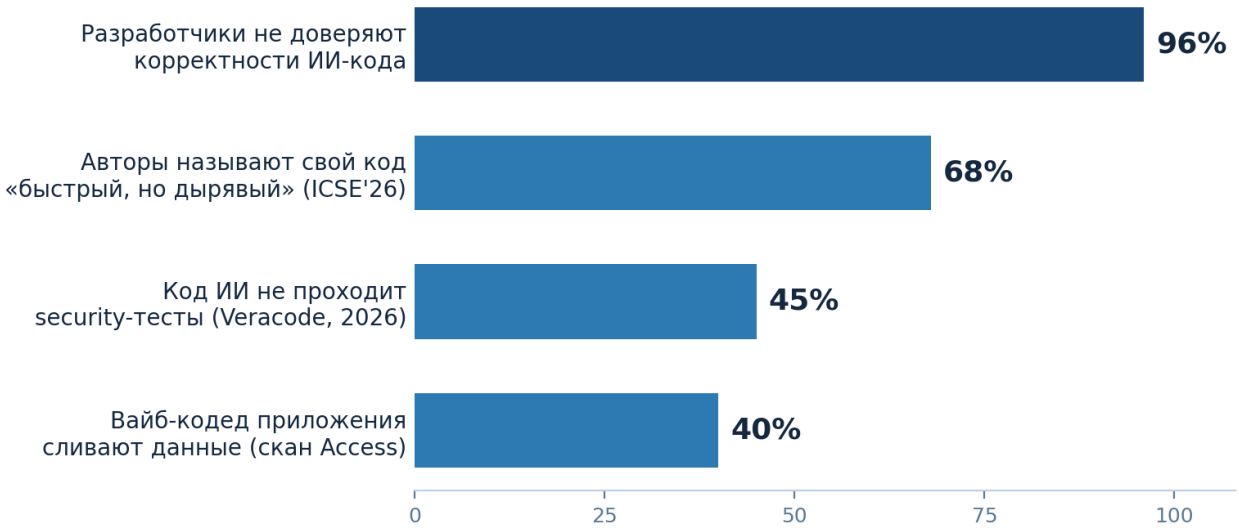


Рис. 1. Качество и доверие к ИИ-сгенерированному коду по данным независимых исследований 2026 года

Классические вендоры безопасности (Snyk, Veracode, Sonar) продают сложные корпоративные платформы командам с CI/CD и выделенными инженерами. Новая аудитория — учитель, собравший сервис записи на приём, маркетолог с лид-магнитом, соло-фаундер микросервиса — у них просто не покупает: у неё нет ни бюджета на SAST-платформу, ни специалиста, который её настроит. Возникла структурная дыра: софта стало больше, чем когда-либо, а инструмента доверия для его длинного хвоста не существует.

45%	40%	12–24 мес
кода ИИ не проходит security-тест	вайб-кодед приложений сливают дан	окно до выхода гигантов в нишу

Отсюда тезис, на котором строится весь продукт: когда создание обесценилось, ценность переехала на этап «после создания» — доверие, отбор, сопровождение и ответственность. AppMOT занимает именно эту позицию. Окно возможностей ограничено: как только категория станет очевидной, её смогут закрыть платформы-конструкторы (но им мешает конфликт интересов) или корпоративные вендоры (но им мешает цена и канал продаж). Первые 12–24 месяца — период, когда независимый игрок может стать стандартом де-факто, как это произошло с SSL-замком и звёздными рейтингами.

2. Продукт: как работает AppMOT

AppMOT — «техосмотр» для приложений, собранных с помощью ИИ. Пользователь вводит адрес живого сайта; внешний, черноящичный движок за 20–40 секунд прогоняет 16 автоматических проверок по четырём категориям и выдаёт оценку A–D, объяснение каждой проблемы человеческим языком, доказательства (что именно было найдено и где) и бейдж, который можно вставить на сайт. Ничего не нужно устанавливать, доступ к коду не нужен — скан видит ровно то, что видит любой посетитель браузера.

2.1. Три шага пользователя

- **Ввод адреса.** Единственное, что нужно от пользователя — публичный URL приложения. Регистрация отложена до момента, когда человек захочет сохранить отчёт или получить бейдж.
- **Скан.** Движок загружает главную страницу и клиентские скрипты, проверяет общедоступные пути (.env, .git, админки, бэкапы), заголовки ответов, TLS-сертификат, CORS, признаки брошенного проекта. Прогресс отображается в реальном времени.
- **Отчёт и действия.** Оценка A–D с кольцевым индикатором, сгруппированные находки с доказательствами, скачиваемый PDF и код бейджа. Каждый проваленный пункт сформулирован так, чтобы его можно было отдать ИИ-агенту на исправление в той же вайб-кодинг-сессии.

2.2. Оценка A–D

Итоговый балл начинается со 100 и уменьшается на вес каждой проблемы: критическая — до 40 пунктов, высокая — до 25, средняя — до 8, низкая — до 5. Действуют потолки: любая критическая находка ограничивает оценку значением 44 (диапазон D), высокая — значением 74 (максимум B). Границы оценок: A — от 85, B — от 70, C — от 45, D — ниже. Механика повторяет логику SSL Labs: простая буква, за которой просматривается воспроизводимая методика.

2.3. Бейдж доверия

Бейдж — вирусный контур продукта. SVG-изображение с оценкой и датой скана вставляется на лендинг приложения и кликается через к актуальному отчёту. Каждое приложение, повесившее бейдж, рекламирует AppMOT; каждая оценка в дикой природе повышает узнаваемость категории. Позже бейджи образуют публичный реестр — каталог проверенных приложений, который становится естественным местом «отбора» в затопленном рынке.

2.4. Демо-режим

Для мгновенной демонстрации ценности в продукт встроен скан намеренно дырявого демо-приложения (отдельный мини-сервис на порту 3210): открытые .env и .git, ключи API в клиентском коде, панель администратора без защиты, бэкап базы по прямой ссылке, заглушки и ошибки в разметке. Демо-скан стабильно показывает оценку D с шестью провалами и восемью предупреждениями — идеальный первый показ для потенциального пользователя или инвестора.

3. Рынок, конкуренты и ров

3.1. Оценка объёма рынка

Точные цифры здесь — предмет отдельного исследования, поэтому приводим консервативную воронку оценок (данные о длине хвоста — из отчётов платформ и App Store; конверсии — оценочные):

Сегмент	Оценка объёма	Комментарий
Вайб-кодеры, запустившие живое приложение (мир)	5–10 млн человек	платформы-конструкторы отчитываются о десятках миллионов проектов; живых — существенно меньше
Приложения с реальными пользователями/деньгами	1,5–3 млн	нижняя граница длинного хвоста микрософта
Платящая аудитория при конверсии 2–4% и ARPU $15–19/мес	$60–140 млн ARR	только подписки Pro; tier Platform и страховка — сверх этого

Табл. 1. Оценка TAM/SAM/SOM (эстиматы, консервативный сценарий)

3.2. Конкурентное поле

Игрок	Что делает	Почему не закрывает нишу
Snyk, Veracode, Sonar	корпоративный SAST/SCA, интеграция с CI/CD, продажа инженерным командам	цена и сложность; у вайб-кодера нет ни CI/CD, ни инженера; сегмент не окупает их модель продаж
Vanta, Drata	автоматизация комплаенса SOC 2 / ISO 27001 для B2B SaaS	комплаенс начинается от $5k/год и адресован компаниям с корпоративными заказчиками, а не микроприложениям
Lovable, Replit, Base44	платформы, на которых собирают приложения; добавляют базовые security-фичи	конфликт интересов: монетизируют объём публикаций, а не их качество; знак качества от автора багги-кода не работает
Сканеры SSL Labs / SecurityHeaders	точечные бесплатные проверки одного аспекта	нет интегральной оценки, нет отчёта для неспециалиста, нет бейджа и мониторинга; это функции, а не продукт

Табл. 2. Конкуренты и структурные причины, по которым ниша остаётся свободной

3.3. Ров

Защитность AppMOT строится на трёх слоях. **Нейтральность:** независимая третья сторона, не зарабатывающая на генерации кода, — единственный, кому можно доверить знак качества; это позиция, недоступная платформам в принципе. **Данные:** каждый скан пополняет датасет «платформа × типовые ошибки» — публичный рейтинг платформ по безопасности их сборок становится цитируемым активом и бесплатным PR-мотором. **Сетевой эффект бейджа:** чем больше сайтов носят бейдж, тем выше доверие к нему и тем дороже отказ платформам-конструкторам от white-label интеграции.

4. Архитектура MVP

MVP собран как один Next.js 16 (App Router, TypeScript) проект: клиентский интерфейс, API-роуты и движок сканера живут в одном приложении, что позволяет запуститься силами одного разработчика и упростить деплой. Движок полностью асинхронный: POST-запрос создаёт запись скана и запускает работу в фоне, клиент опрашивает статус — поэтому долгие проверки не блокируют соединение и масштабируются горизонтально.



Рис. 2. Компоненты MVP и поток данных: UI → API-роуты → движок → цели скана

4.1. Принципы движка

- **Черный ящик.** Только внешние HTTP-запросы, никаких эксплойтов и агрессивных техник: то же, что делает любой посетитель сайта за пять минут ручной проверки.
- **Ограниченный бюджет.** Таймауты 5–12 секунд на запрос, не более 600 КБ на ответ, конкурентность 4, суммарно ~40 запросов на скан; нагрузка на цель сопоставима с одним нетерпеливым посетителем.
- **Без хранения секретов.** Найденные ключи маскируются до записи в отчёт; полные значения не сохраняются и не показываются даже владельцу.
- **Локализуемость.** Каждая проверка возвращает объяснения сразу на двух языках (RU/EN) — отчёт генерируется на языке интерфейса пользователя.

Компонент	Технология	Назначение и путь в коде
Интерфейс	Next.js 16, React 19, Tailwind 4, shadcn/ui	лендинг, ввод URL, прогресс, отчёт — src/app/page.tsx, src/components/report-view.tsx
API-роуты	Route Handlers (Node runtime)	POST /api/scan, GET /api/scan/[id], GET /api/badge, GET /api/report — src/app/api/
Движок сканера	TypeScript, fetch + node:tls	16 проверок в 4 модулях, оркестратор, грейдер — src/lib/scanner/
Хранилище	JSON-файл на скан	db/scans/*.json; при росте заменяется на Postgres/Redis без изменения контракта
PDF-генератор	pdf-lib + fontkit, DejaVu	двухстраничный отчёт с кириллицей — src/lib/scanner/report-pdf.ts
Демо-цель	bun mini-service :3210	намеренно дырявое приложение для демонстрации — mini-services/demo-app/

Табл. 3. Состав MVP и соответствие файлам репозитория

Осознанные ограничения MVP: очередь сканов в памяти одного процесса, отсутствие аккаунтов и биллинга, ручной запуск демо-сервиса. Все три точки спроектированы как сменные модули — контракт API и формат записи скана не меняются при переходе на Postgres и платёжный шлюз.

5. Каталог проверок движка v1

Шестнадцать проверок сгруппированы в четыре категории, выбранные по данным реальных сканов вайб-кодед приложений: они покрывают и самые дорогие ошибки (утечка ключей, открытая база), и самые частые признаки недостроенности (заглушки, битые ссылки). Вес в скобках — вычитаемые баллы при провале; «warn» означает частичное нарушение и пропорциональное снижение.

ID	Проверка	Метод	Сев.
env_exposure	Файл .env доступен из сети	GET /.env, /.env.local, /.env.* и разбор содержимого	crit · 40
git_exposure	Каталог .git скачивается	GET /.git/HEAD, поиск «ref: refs/»	crit · 35
secrets_in_source	Ключи API в HTML и JS-бандлах	загрузка до 6 бандлов, сигнатуры OpenAI/AWS/Stripe/Google/SendGrid, приватные ключи, generic-паттерн	crit · 40
baas_open_read	Firebase/Supabase читается анонимно	извлечение projectId из JS, GET /.json у RTDB, REST Supabase	crit · 35
source_maps	Source maps в продакшене	HEAD на *.js.map у подключенных бандлов	low · 3
security_headers	CSP, HSTS, X-Frame-Options и др.	разбор заголовков главного ответа	med · до 19
cors_wildcard	CORS открыт для любого Origin	запрос с Origin evil.example, разбор ACAO/ACAC	med–high · 8–15
cookie_flags	Cookie без HttpOnly/Secure/SameSite	разбор Set-Cookie главного ответа	med · до 9
tls_cert	Сертификат истёк / истекает / нет HTTPS	TLS-рукопожатие (node:tls), срок действия в днях	crit–high · 15–35
admin_exposure	Админ-панель на стандартных путях	GET /admin, /wp-admin, /dashboard и др.; маркеры панелей	high · 15
backup_files	Дампы БД и бэкапы по прямым ссылкам	GET /backup.zip, /dump.sql, /db.sqlite3 и др., контроль размера	crit · 40
debug_endpoints	Отладочные эндпоинты отвечают	GET /api/debug, /debug/vars, /actuator/env, JSON-ответ	med · 8
placeholder_content	Заглушки (lorem ipsum, Coming soon)	паттерны по разметке главной	low · 4

ID	Проверка	Метод	Сев.
rendered_errors	«undefined»/«NaN» в разметке	очистка script/style, поиск артефактов	low · 5
broken_links	Битые внутренние ссылки	извлечение до 8 ссылок, HEAD с fallback GET	med · 8
meta_health	Пустые title/description	разбор head главной страницы	low · 3

Табл. 4. Каталог проверок v1: 16 пунктов, четыре категории, веса для итогового балла

Проверка платформы-конструктора (Lovable, Replit, Bolt, Framer, v0/Vercel, Base44) выполняется в каждом скане как информационная: она питает будущий рейтинг платформ и не влияет на оценку.

6. API-спецификация

Контракт минималистичен и уже реализован в MVP; он же станет основой Platform-тарифа. Все ответы — JSON, кроме бейджа (SVG) и отчёта (PDF). Аутентификация в MVP отсутствует, в продакшене — Bearer-токен и rate limit на IP/токен.

Метод и путь	Назначение	Ответ
POST /api/scan	старт скана: {url, lang: ru|en}	{id} — идентификатор для опроса
GET /api/scan/{id}	статус и результат: прогресс, стадия, затем оценка, находки с доказательствами	ScanResult JSON
GET /api/badge?id={id}	SVG-бейдж с оценкой; theme=light|dark	image/svg+xml, кэш 5 минут
GET /api/report?id={id}	PDF-отчёт на языке скана	application/pdf, вложение

Табл. 5. Эндпоинты MVP

```
$ curl -s -X POST localhost:3000/api/scan \
    -H 'content-type: application/json' \
    -d '{"url": "demo://app", "lang": "ru"}'
{"id": "mwcgym4s-7l7ou6"}

# через 15–40 секунд:
$ curl -s localhost:3000/api/scan/mwcgym4s-7l7ou6 | jq '{status, grade, score}'
{"status": "done", "grade": "D", "score": 0}
```

Поля результата спроектированы под три потребителя: человек (title/detail на двух языках, группировка по категориям), ИИ-агент (стабильные id проверок, машинные коды находок, доказательства в текстовом виде — достаточные для автофикса) и будущий реестр бейджей (host, score, grade, timestamp). Это позволит позже открывать API для платформ без ломающих изменений.

7. Юнит-экономика

7.1. Тарифная сетка

Тариф	Цена	Что входит	Роль в воронке
Free	$0	1 полный скан в день, оценка, отчёт, бейдж, PDF	активация категории, вирусный контур бейджа
Pro	$19/мес	безлимит сканов, недельный мониторинг, автоперепроверка после релиза, бейдж со свежей датой	основная выручка; отвечает страху «мой проект заброшен и протух»
Platform	от $499/мес	API, white-label бейджи, массовый скан каталога, SLA	продажа платформам-конструкторам и хостингам; 2–3 контракта закрывают годовой runway

Табл. 6. Тарифы (цены — гипотеза для тестирования, валюта USD)

7.2. Экономика скана и подписчика (оценки)

Серверная стоимость одного скана складывается из вычислений (20–40 HTTP-запросов, до 3 МБ трафика, 20–40 секунд CPU-времени с ожиданиями по таймаутам) и оценивается в $0,01–0,02 при запуске на одной VPS за $40–60/мес; после перехода на бессерверные воркеры — в пределах $0,03. Даже при безлимитном Pro тарифе активный пользователь генерирует в среднем 15–25 сканов в месяц, то есть маржинальная стоимость обслуживания Pro-подписчика — около $0,30–0,50 в месяц против $19 выручки. Стоимость привлечения через контент-луп (публичные отчёты-рейтинги, бейджи, SEO) на старте близка к нулю в деньгах, но требует 10–15 часов контент-работы в неделю; платный канал допустим при CAC не выше $40–45, что даёт LTV/CAC не хуже 3 при годовом удержании Pro около 60%. Все цифры — эстиматы для проверки на первых 100 клиентах.

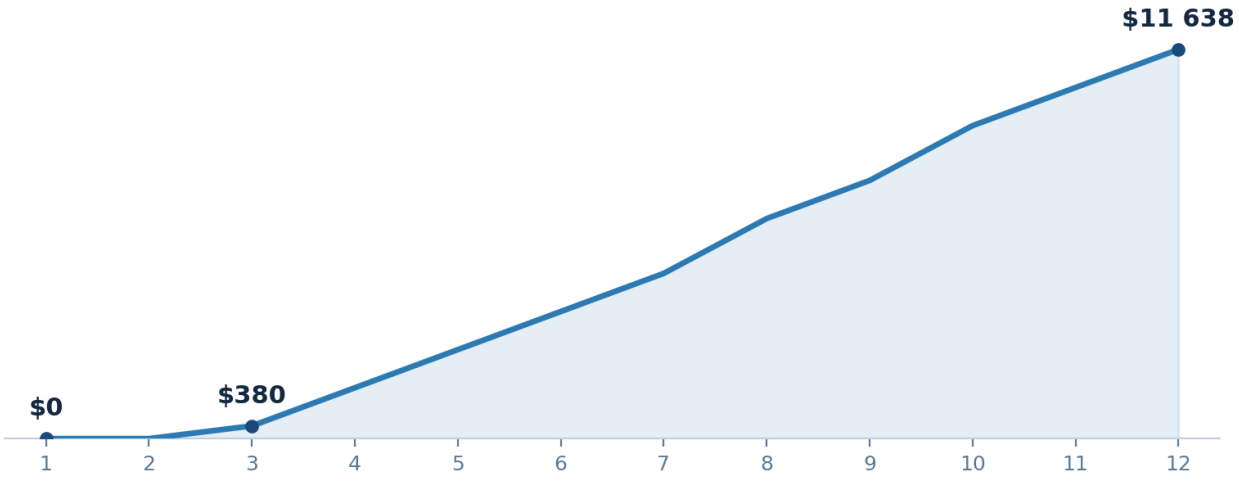


Рис. 3. Прогноз MRR на 12 месяцев (модель: запуск платных подписок в мес. 3, +60 Pro/мес, 2 контракта Platform с мес. 8–10; все допущения — эстиматы)

Модель на рис. 3 консервативна: она не включает разовые отчёты-аудиты для агентств ($150–300 за шт., отдельная продуктовая гипотеза) и эффект вирусного бейджа. Ключевое допущение — темп +60 Pro в месяц; его реалистичность проверяется на этапе 90-дневного плана (глава 8). Точка безубыточности по постоянным расходам (~$500/мес: VPS, домены, почта, мониторинг) достигается на 25–30 Pro-подписках.

8. План первых 90 дней

План устроен по принципу «каждая неделя производит проверяемый артефакт». Успех этапа определяется не количеством фич, а первыми подписками: цель 90 дней — 20–30 Pro-подписчиков и один пилюльный кейс с публичным рейтингом платформ.

Недели	Фокус	Результат на выходе
1–2	доводка движка и UI MVP	стабильные 16 проверок, полировка отчёта, обработка ошибок сети, деплой на домен
3–4	публичный отчёт-рейтинг №1	скан 300–500 приложений из публичных галерей платформ; публикация «State of Vibe-Coded App Security»; PR-рассылка
5–6	запуск на сообщества	Show HN, Product Hunt, сабреддиты r/SideProject и r/vibecoding; сбор первых 500 Free-пользователей
7–8	бейдж и ретеншн	витрина бейджей, еженедельные письма «что изменилось в вашем приложении», метрики D7
9–10	включение биллинга Pro	Stripe, лимиты Free, Early-bird $9/мес для первых 100; цель — первые 10 платящих
11–13	исходящие для Platform	питч 20 платформам-конструкторам и хостингам с данными рейтинга; цель — 1 пилот white-label

Табл. 7. 90-дневный план запуска

Главный риск плана — застрять в разработке. Поэтому недели 3–4 intentionally переносят фокус с кода на данные: публичный отчёт является одновременно и маркетингом, и валидацией спроса — по количеству переходов с отчёта на сканы видно, конвертирует ли тема.

9. Дорожная карта на 12 месяцев

Эволюция продукта движется от «одноразового осмотра» к «непрерывному доверию» — каждый этап монетизируется независимо и расширяет ров предыдущего.

Период	Этап	Что появляется	Метрика успеха
Мес 1–3	Техосмотр	скан по URL, оценка A–D, PDF, бейдж, Free/Pro	1 000 сканов, 20–30 Pro
Мес 4–6	Мониторинг	еженедельные перепроверки, письма об изменениях, история оценок	отток Pro ниже 5%/мес
Мес 7–8	Автофикс-агент	готовые патчи для типовых провалов: заголовки, правила Firebase, .env	30% провалов закрываются одним кликом
Мес 9–10	Реестр бейджей	публичный каталог проверенных приложений, страница платформы в рейтинге	5 000 живых бейджей
Мес 11–12	Страховая обвязка	гарантия «если протекло аттестованное приложение — платим мы» со страховым партнёром	подписан пилот со страховщиком/брокером

Табл. 8. Дорожная карта: бейдж → мониторинг → автофикс → реестр → страховка → API для платформ

Страховой этап — стратегическая вершина: он превращает оценку AppMOT из справки в финансовый инструмент и создаёт эффект Vanta-модели, когда аттестация оплачивает себя экономией на премии. Параллельно с месяца 9 открывается Platform API: контракты с платформами дают многократный скачок объёма сканов и данных без роста CAC.

10. Риски и митигации

Риск	Вероятность	Митигация
Платформа-конструктор выпускает встроенный «trust score»	средняя	нейтральность: оценка от вендора генерации не воспринимается как независимая; фокус на кросс-платформенности и реестре
Юридические претензии за сканирование сайтов	низкая	только публичные страницы, щадящая нагрузка, robots-этика, прозрачный юзер-агент, opt-out по письму
Найденные секреты становятся источником утечки через сам сервис	средняя	маскирование до записи, без хранения полных значений, шифрование хранилища, короткий ретеншн
Низкая платёжеспособность аудитории	средняя	сдвиг выручки в Platform-контракты и страховку; Free-тариф остаётся маркетингом, а не бизнесом
Ложные срабатывания подрывают доверие к оценке	средняя	режим «подтверди находку» с ручной проверкой спорных кейсов, публикация методики каждой проверки
Окно закрывается быстрее 12 месяцев	низкая	скорость: публичные данные и бейдж-сеть нельзя воспроизвести за квартал; при необходимости — M&A-;исход

Табл. 9. Реестр рисков MVP

Итог: MVP уже реализован и проверен на живых сайтах и демо-цели; всё перечисленное выше — не теория, а описание работающего прототипа и план его превращения в бизнес. Следующий шаг — недели 3–4 плана: публичный отчёт-рейтинг, который за один ход даёт данные, прессу и первый поток пользователей.